

ControlSphere

Complete Mathematical & Risk Formula Reference

Phases 1–9: Deterministic Governance, Risk, Compliance, Assurance & TPM Telemetry

Document Version:	1.0.0 (Production Release)	Status:	APPROVED & AUTHORITATIVE
Repository Reference:	Commit 65f4ee8	Date:	August 26, 2026
Alembic Schema Head:	0009_tprm (Head)	Test Baseline:	330 / 330 Tests Passing (100%)
Execution Engine:	Server-Authoritative Python 3.12	Architecture Scope:	Phases 1 through 9 Complete

Executive Summary

This document constitutes the comprehensive, definitive mathematical and algorithmic reference for all deterministic scoring engines, risk models, decay algorithms, weighting matrices, boundary thresholds, and assurance calculations across the entire **ControlSphere** enterprise GRC platform. ControlSphere enforces strict server-authoritative calculations with 0% client-controlled metrics, deterministic reproducible math, and continuous multi-regulatory posture lineage.

Table of Contents

Section	Title & Coverage Area	Phase Scope
Section 1	Formula Governance & Mathematical Principles	Cross-Platform
Section 2	Phase-by-Phase Comprehensive Formula Inventory	Phases 1–9
Section 3	Phases 1–5 Core Governance & Risk Matrix Calculations	Phases 1–5
Section 4	Phase 6: Audit Readiness & Assurance Scoring Engine	Phase 6
Section 5	Phase 7: Continuous Control Monitoring (CCM) Health Engine	Phase 7
Section 6	Phase 8: Multi-Framework Harmonization & Control Rationalization	Phase 8
Section 7	Phase 9: Third-Party & Vendor Cyber Risk Management (TPRM)	Phase 9
Section 8	Consolidated Threshold, Coefficient & Boundary Reference Matrix	Phases 1–9
Section 9	Fully Worked Numerical Examples (11 Benchmark Scenarios)	Phases 6–9
Section 10	Formula Dependency Lineage & Telemetry Propagation Architecture	Platform Lineage
Section 11	Specification vs. Implementation Verification Notes	Audit Analysis
Section 12	Source Code & Pytest Test Suite Traceability Directory	Code Map
Section 13	Formula Quick Reference & Engineering Cheat Sheet	Executive Summary

Section 1: Formula Governance & Mathematical Principles

ControlSphere strictly adheres to foundational software engineering and cybersecurity governance principles governing all numerical calculations:

CORE MATHEMATICAL GOVERNANCE TENETS

- Server-Authoritative Execution:** No computed values (health scores, inherent risk, residual risk, coverage percentages, readiness scores, compliance indexes) are ever accepted from client payloads. All mathematical metrics are calculated exclusively server-side in Python services.
- Deterministic Computation:** Given the identical operational state (evidence timestamps, finding severities, assessment responses, crosswalk weights), the scoring engines produce 100% bitwise-identical mathematical results. No non-deterministic random variables or unanchored heuristics are employed.
- No Stochastic / Unverifiable AI Scoring:** ControlSphere strictly prohibits AI/LLM models from generating risk scores, audit readiness percentages, or compliance health values. Human reviewers issue opinions; deterministic engines calculate math.
- Explicit Numerical Clamping:** All percentage and normalized score scales are mathematically clamped to their legitimate physical boundaries: $[0.0, 100.0]$ for percentages and health scores, $[1, 25]$ for 5×5 risk matrices, and $[0.0, 1.0]$ for crosswalk confidence.
- Standardized Decimal Rounding:** All user-facing scores and percentages are rounded to 1 decimal place using standard mathematical rounding ($\text{round}(val, 1)$). Crosswalk confidence scores are rounded to 2 decimal places ($\text{round}(val, 2)$).
- Historical Immutability:** Point-in-time snapshots (such as `ControlHealthSnapshot`, `FrameworkComplianceSnapshot`, and approved `VendorAssessment` line items) are permanently immutable once written. Superseded records preserve historical metrics without modification.

Section 2: Phase-by-Phase Formula Inventory

Phase	Formula / Engine Name	Mathematical Purpose	Responsible Service	Output Domain
Phase 1	Tenant Isolation & RBAC Gate	Cryptographic hash check & bitwise role-permission resolution	AuthService / permissions.py	Boolean / Set
Phase 2	Control Compliance Score %	Measures framework implementation ratio	ControlService	$[0.0, 100.0]\%$
Phase 3	Evidence Coverage %	Measures satisfied mandatory evidence requirements	EvidenceService	$[0.0, 100.0]\%$
Phase 4	Finding Risk Matrix (\$5 imes 5\$)	Evaluates finding risk score & severity band	FindingService / risk_engine.py	$[1, 25]\$ / 4$ Bands
Phase 4	Finding SLA Overdue Status	Determines remediation timeliness against target dates	FindingService / risk_engine.py	4 Status Enums
Phase 5	Enterprise Risk Register Scoring	Computes Inherent & Residual risk scores & appetite status	RiskService / risk_engine.py	$[1, 25]\$ / Appetite$
Phase 5	Risk Reduction %	Measures treatment effectiveness: $(I - R) / I \text{ imes } 100\%$	RiskService	$[0.0, 100.0]\%$
Phase 6	Audit Procedure Completion %	Ratio of completed procedures to total scoped procedures	AuditEngagementService	$[0.0, 100.0]\%$
Phase 6	Audit Evidence Coverage %	Ratio of in-scope controls with accepted evidence	AuditEngagementService	$[0.0, 100.0]\%$
Phase 6	Audit Readiness Master Score	Weighted synthesis: $0.40 \text{ ext{Proc}} + 0.30 \text{ ext{Evd}} - P_{\text{ext{audit}}}\%$	AuditEngagementService	$[0.0, 100.0]\$ / 4$ Bands
Phase 7	Evidence Freshness Decay (\$E\$)	Linear aging decay over $2 \text{ imes } \$$ threshold window	MonitoringService	$[0.0, 100.0]\%$
Phase 7	Assessment Currency Metric (\$A\$)	Step-wise valuation based on implementation status & age	MonitoringService	$\{0, 25, 50, 60, 100\}\%$
Phase 7	Finding Penalty Score (\$P_F\$)	Severity-weighted accumulation with SLA breach multipliers	MonitoringService	$[0.0, \infty)\%$
Phase 7	Exception Penalty Score (\$P_E\$)	Penalty for active approved (+5) and expired (+15) exceptions	MonitoringService	$[0.0, \infty)\%$
Phase 7	Master CCM Health Score	$E \text{ imes } 0.35 + A \text{ imes } 0.25 + (40 - \min(40, P_F + P_E))\%$	MonitoringService	$[0.0, 100.0]\$ / 4$ Bands
Phase 8	Common Control Inherited Health	Weighted average of mapped organization controls' CCM scores	HarmonizationService	$[0.0, 100.0]\$ / 4$ Bands
Phase 8	Framework Direct Coverage	Evaluates $\text{ext{status}} = \text{ext{IMPLEMENTED}} \wedge \text{ext{CCMHealth}} \geq 60.0\%$	HarmonizationService	Boolean
Phase 8	Crosswalk Inherited Coverage	Evaluates mapped candidate with $\text{ext{conf}} \geq 0.80 \wedge \text{ext{CCM}} \geq 60.0\%$	HarmonizationService	Boolean
Phase 8	Framework Coverage %	$\frac{ S_{\text{ext{direct}}} \cup S_{\text{ext{crosswalk}}} }{N_F \text{ imes } 100.0\%}$	HarmonizationService	$[0.0, 100.0]\%$
Phase 8	Framework Compliance Health Score	$\sum \text{ext{EffectiveHealth}} / N_F\%$	HarmonizationService	$[0.0, 100.0]\%$
Phase 9	Vendor Engagement Risk Score	$0.30C + 0.30D + 0.20N + 0.10P + 0.10H\%$	TPRMService	$[0.0, 100.0]\%$
Phase 9	Vendor Inherent Risk Score	$\max_{e \in \text{ext{ActiveEngagements}}} (\text{ext{EngagementRisk}}(e))\%$	TPRMService	$[0.0, 100.0]\%$
Phase 9	Deterministic Tier Mapping	Maps Inherent Risk & Criticality escalation to Tiers 1–4	TPRMService	4 Tier Enums

Phase	Formula / Engine Name	Mathematical Purpose	Responsible Service	Output Domain
Phase 9	Assessment Questionnaire Score	Weighted response ratio excluding NOT_APPLICABLE	TPRMService	\$(0.0, 100.0]\%\$
Phase 9	Vendor Residual Risk Engine	$\text{clamp}(\max(\text{Floor}, \text{Base}) + P_{\text{find}} + P_{\text{exc}}, 0, 100)$	TPRMService	\$(0.0, 100.0]\$ / 4 Bands

Section 3: Phases 1–5 Core Governance & Risk Calculations

3.1 Phase 2: Framework Control Compliance Score

Located in backend/app/services/control_service.py. Evaluates the aggregate implementation maturity of a framework:

CONTROL COMPLIANCE SCORE FORMULA

$$\text{ApplicableCount} = N_{\text{total}} - N_{\text{NOT_APPLICABLE}}$$

$$\text{EffectiveScore} = (N_{\text{IMPLEMENTED}} \times 1.0) + (N_{\text{PARTIALLY_IMPLEMENTED}} \times 0.5)$$

$$\text{ComplianceScorePct} = \text{round}\left(\frac{\text{EffectiveScore}}{\text{ApplicableCount}} \times 100.0, 1\right) \text{ if } \text{ApplicableCount} > 0 \text{ else } 0.0$$

Weighting: Implemented controls receive 100% weight (\$1.0\$), Partially Implemented receive 50% weight (\$0.5\$), In Progress / Not Started receive 0% weight (\$0.0\$). Controls marked NOT_APPLICABLE are entirely excluded from both numerator and denominator.

3.2 Phase 3: Evidence Requirement Coverage

Located in backend/app/services/evidence_service.py. Evaluates the ratio of satisfied mandatory evidence requirements:

EVIDENCE REQUIREMENT COVERAGE FORMULA

$$\text{CoveragePercentage} = \text{round}\left(\frac{|\{r \in \mathcal{R}_{\text{mandatory}} \mid \exists e \in \mathcal{E}_{A(r)}\}|}{|\mathcal{R}_{\text{mandatory}}|} \times 100.0, 1\right)$$

Where $\mathcal{R}_{\text{mandatory}}$ is the set of required evidence requirements, and $\mathcal{E}_{A(r)}$ is the set of items linked to requirement r with status ACCEPTED. If no mandatory requirements exist, coverage is 100.0% if any accepted item exists, else 0.0%.

3.3 Phase 4 & 5: Deterministic \$5 imes 5\$ Risk Matrix Engine

Located in backend/app/core/risk_engine.py. Shared across findings and risk register:

DETERMINISTIC RISK MATRIX ENGINE (\$5 IMES 5\$)

$$\text{RiskScore} = \text{clamp}(\text{Impact}, 1, 5) \times \text{clamp}(\text{Likelihood}, 1, 5) \in [1, 25]$$

Risk Score Range	Risk Band	Impact × Likelihood Coordinates	Appetite Boundary
[1, 4]	LOW	(1,1), (1,2), (1,3), (1,4), (2,1), (2,2), (3,1), (4,1)	Within Low Appetite
[5, 9]	MODERATE	(1,5), (2,3), (2,4), (3,2), (3,3), (4,2), (5,1)	Within Moderate Appetite
[10, 16]	HIGH	(2,5), (3,4), (3,5), (4,3), (4,4), (5,2), (5,3)	Within High Appetite
[17, 25]	CRITICAL	(4,5), (5,4), (5,5)	Exceeds High Appetite

Section 4: Phase 6 — Audit Readiness & Assurance Scoring Engine

Located in backend/app/services/audit_engagement_service.py. Deterministically evaluates whether an audit engagement is prepared for formal review and assurance opinion issuance.

AUDIT READINESS SCORE MASTER FORMULA

$$\text{ReadinessScore} = \text{round}\Big(\max\big(0.0, \min(100.0, (\text{Score}_{\text{proc}} \times 0.40) + (\text{Score}_{\text{evd}} \times 0.30) - P_{\text{audit}}\big)\Big), 1\Big)$$

4.1 Constituent Components

1. Procedure Completion Score (\$Score_{proc}\$) — Weight: 40%

$$\text{Score}_{\text{proc}} = \begin{cases} \left(\frac{N_{\text{PASSED}} + N_{\text{PARTIALLY_PASSED}} + N_{\text{FAILED}} + N_{\text{NOT_APPLICABLE}}}{N_{\text{total_procedures}}} \times 100.0 \right) & \text{if } N_{\text{total_procedures}} > 0 \\ 0.0 & \text{otherwise} \end{cases}$$

Procedures in NOT_STARTED or IN_PROGRESS do not count as completed.

2. In-Scope Evidence Coverage Score (\$Score_{evd}\$) — Weight: 30%

$$\text{Score}_{\text{evd}} = \begin{cases} \left(\frac{N_{\text{controls_with_accepted_evidence}}}{N_{\text{controls_in_scope}}} \times 100.0 \right) & \text{if } N_{\text{controls_in_scope}} > 0 \\ 0.0 & \text{otherwise} \end{cases}$$

3. Unresolved Finding Penalties (\$P_{audit}\$)

$$P_{\text{crit_high}} = \min\big((N_{\text{critical_findings}} + N_{\text{high_findings}}) \times 5.0, 20.0\big)$$

$$P_{\text{open}} = \min(N_{\text{open_findings}} \times 2.0, 10.0)$$

$$P_{\text{audit}} = P_{\text{crit_high}} + P_{\text{open}} \quad (\text{Maximum Penalty Cap: } 30.0)$$

4.2 Audit Readiness Bands & Blocker Triggers

Readiness Band	Score Range	Audit State Implication
READY	[85.0, 100.0]	Procedures complete, evidence in place, zero high/critical blockers. Ready for opinion issuance.
SUBSTANTIALLY_READY	[60.0, 84.9]	Minor procedural or evidence gaps remain; remediation on track.
PARTIALLY_READY	[35.0, 59.9]	Significant gaps in testing procedures or missing evidence on scoped controls.
NOT_READY	[0.0, 34.9]	Critical unmitigated findings, unperformed procedures, or absent evidence.

DETERMINISTIC READINESS BLOCKERS GENERATED

- "{N} critical/high finding(s) unresolved": Triggered when $N_{\text{critical}} + N_{\text{high}} > 0$.
- "{N} open finding(s) pending remediation": Triggered when $N_{\text{open}} > 0 \wedge (N_{\text{critical}} + N_{\text{high}} = 0)$.
- "No audit procedures defined": Triggered when $N_{\text{total_procedures}} = 0$.
- "{N} procedure(s) not yet started": Triggered when $N_{\text{NOT_STARTED}} > 0$.
- "No controls added to audit scope": Triggered when $N_{\text{controls_in_scope}} = 0$.
- "{N} in-scope control(s) lack accepted evidence": Triggered when $N_{\text{controls_with_evidence}} < N_{\text{controls_in_scope}}$.

Section 5: Phase 7 — Continuous Control Monitoring (CCM) Health Engine

Located in backend/app/services/monitoring_service.py and specified in PHASE7_CANONICAL_SPEC.md. Evaluates real-time operational health of controls based on live telemetry.

CANONICAL CCM HEALTH SCORE MASTER FORMULA

$$\text{RawScore}(c) = \text{Big}(E(c) \times 0.35) + \text{Big}(A(c) \times 0.25) + \text{Big}(40.0 - \min(\text{Big}(40.0 - P_F(c) + P_E(c)), \text{Big}))$$

$$\text{HealthScore}(c) = \text{round}(\text{Big}(\max(0.0, \min(100.0, \text{RawScore}(c))), 1))$$

5.1 Constituent Metrics & Degradation Curves

1. Evidence Freshness Metric (\$E\$) — Max Contribution: \$35.0 pts\$

Let Δ_{ev} be the age in days of the latest ACCEPTED evidence item for control c , and $au_{ev} = \text{evidence_max_age_days}$ (default 90 days):

$$E(c) = \begin{cases} 0.0 & \text{if no accepted evidence exists} \\ 100.0 & \text{if } \Delta_{ev} \leq au_{ev} \text{ (Fresh)} \\ \text{round}(\left(\max\left(0.0, 1.0 - \frac{\Delta_{ev} - au_{ev}}{au_{ev}}\right) \times 100.0, 1\right)) & \text{if } \Delta_{ev} > au_{ev} \text{ (Linear Decay)} \end{cases}$$

Decay Dynamics: Over days $au_{ev} \rightarrow 2 \times au_{ev}$ (\$90 \rightarrow 180\$ days), the freshness score decreases linearly from \$100.0 to 0.0\$. At day 135 (45 days stale), $E = 50.0$. At ≥ 180 days, $E = 0.0$.

2. Assessment Currency Metric (\$A\$) — Max Contribution: \$25.0 pts\$

Evaluates formal control review status and age (Δ_{assess}) against $au_{assess} = 180$ days:

Control Implementation Status	Assessment Age Condition	Currency Score (\$A\$)	Weighted Pts (\$A \times 0.25\$)
IMPLEMENTED	$\Delta_{assess} \leq 180$ days (Current)	\$100.0\$	\$25.0 pts\$
IMPLEMENTED	$\Delta_{assess} > 180$ days (Overdue)	\$60.0\$	\$15.0 pts\$
PARTIALLY_IMPLEMENTED	Any Age	\$50.0\$	\$12.5 pts\$
IN_PROGRESS / NEEDS_REVIEW	Any Age	\$25.0\$	\$6.25 pts\$
NOT_STARTED / NOT_APPLICABLE	Any Age	\$0.0\$	\$0.0 pts\$

3. Finding Penalty Score (\$P_F\$) & Exception Penalty Score (\$P_E\$) — Baseline Credit: \$40.0 pts\$

Penalties deduct directly from the 40-point baseline credit, capped at a maximum deduction of \$40.0 points:

Finding / Exception Condition	Base Penalty	SLA Breach Surcharge	Total Penalty
CRITICAL Finding (\$ ext{Age} \le 15 ext{d}\$)	\$+20.0\$	\$+0.0\$	\$+20.0\$
CRITICAL Finding (\$ ext{Age} > 15 ext{d}\$ SLA Breach)	\$+20.0\$	\$+10.0\$	\$+30.0\$
HIGH Finding (\$ ext{Age} \le 30 ext{d}\$)	\$+10.0\$	\$+0.0\$	\$+10.0\$
HIGH Finding (\$ ext{Age} > 30 ext{d}\$ SLA Breach)	\$+10.0\$	\$+5.0\$	\$+15.0\$
MEDIUM Finding	\$+4.0\$	\$+0.0\$	\$+4.0\$
LOW / INFORMATIONAL Finding	\$+1.0\$	\$+0.0\$	\$+1.0\$
Active Approved Security Exception (\$ ext{Expiry} \ge ext{Today}\$)	\$+5.0\$	\$+0.0\$	\$+5.0\$
Expired Active Security Exception (\$ ext{Expiry} < ext{Today}\$)	\$+15.0\$	\$+0.0\$	\$+15.0\$

5.2 Health Status Bands & Numerical Boundaries

Health Band	Exact Numerical Boundary	Operational Meaning & Compliance Status
HEALTHY	[\$80.0, 100.0]\$	Control compliant, fresh evidence, current assessment, no major findings.
DEGRADED	[\$60.0, 79.9]\$	Moderate gaps, assessment aging, or minor/moderate findings present.
AT_RISK	[\$40.0, 59.9]\$	Stale evidence, unassessed control, or open high findings.
FAILING	[\$0.0, 39.9]\$	Critical deficiencies, SLA breaches, expired exceptions, or total lack of evidence.

Section 6: Phase 8 — Multi-Framework Harmonization & Control Rationalization

Located in `backend/app/services/harmonization_service.py` and specified in `PHASE8_ARCHITECTURE.md`. Implements the "Assess Once, Comply with Many" cross-regulatory governance engine.

6.1 Rationalized Common Control Inherited Health

Aggregates Phase 7 CCM health scores across all mapped organization controls:

COMMON CONTROL INHERITED HEALTH FORMULA

$$\text{InheritedHealth}(CC) = \begin{cases} 100.0 & \text{if no mapped controls exist} \\ \text{round}\left(\max\left(0.0, \min\left(100.0, \frac{\sum_{m \in \mathcal{M}(CC)} w_m \cdot \text{CCMScore}(m)}{\sum_{m \in \mathcal{M}(CC)} w_m}\right)\right), 1\right) & \text{otherwise} \end{cases}$$

Weight Constraints: Individual mapping weights w_m are bounded by $w_m \leq 0.1$. The denominator is guarded by $\max(0.1, \sum w_m)$ preventing zero division.

6.2 Subcategory Coverage & Effective Health Classification

DIRECT VS. CROSSWALK INHERITED COVERAGE RULES

1. Direct Coverage Condition:

$$\text{DirectlyCovered}(s) \iff \text{Status}(s) = \text{IMPLEMENTED} \land \text{CCMHealth}(s) \geq 60.0$$

$$\text{EffectiveHealth}_{\text{direct}}(s) = \text{CCMHealth}(s)$$

2. Crosswalk Inherited Coverage Condition (Evaluated if not directly covered):

Let $\mathcal{C}(s)$ be the set of crosswalk mappings linking target subcategory s to source subcategory s_{src} where $\text{Confidence}(cw) \geq 0.80$, $\text{Status}(s_{\text{src}}) = \text{IMPLEMENTED}$, and $\text{CCMHealth}(s_{\text{src}}) \geq 60.0$:

$$\text{EffectiveHealth}_{\text{cand}}(cw) = \text{round}\left(\frac{\text{CCMHealth}(s_{\text{src}}) \cdot \text{Confidence}(cw)}{\sum_{cw} \text{Confidence}(cw)}, 1\right)$$

3. Deterministic Multi-Candidate Resolution:

If multiple crosswalk candidate paths exist for subcategory s , the engine selects the candidate with the highest precedence sorted by:

```
candidates.sort(key=lambda x: (-x[0], -x[1], x[2])) # (-effective_health, -confidence, cw.id)
```

Deterministic Tie-Breaker: 1st: Highest Effective Health • 2nd: Highest Confidence Score • 3rd: Lowest Crosswalk ID ($cw.id$).

6.3 Framework Coverage & Compliance Score

FRAMEWORK POSTURE MASTER FORMULAS

$$\text{CoveragePercentage}(F) = \text{round}\left(\frac{|S_{\text{direct}}(F) \cup S_{\text{crosswalk}}(F)|}{N_{\text{total_subcategories}}(F)} \times 100.0, 1\right)$$

$$\text{ComplianceHealthScore}(F) = \text{round}\left(\max\left(0.0, \min\left(100.0, \frac{\sum_{s \in S_{\text{covered}}(F)} \text{EffectiveHealth}(s)}{N_{\text{total_subcategories}}(F)}\right)\right), 1\right)$$

Calculation Versioning: Every snapshot is permanently tagged with `calculation_version = "v1.0"` to guarantee complete audit reproducibility across future algorithm revisions.

Section 7: Phase 9 — Third-Party & Vendor Risk Management (TPRM)

Located in backend/app/services/tpm_service.py. Deterministically models supply-chain and third-party vendor risk.

7.1 Vendor Engagement Risk Engine

VENDOR ENGAGEMENT RISK FORMULA			
$\text{EngagementRisk} = \text{round}\left(\frac{0.30 \cdot C + 0.30 \cdot D + 0.20 \cdot N + 0.10 \cdot P + 0.10 \cdot H}{1}\right)$			
Dimension	Weight	Enum Value	Point Scale
Business Criticality (\$C\$)	\$30\%\$	CRITICAL	\$100.0\$
		HIGH	\$75.0\$
		MEDIUM	\$50.0\$
		LOW	\$25.0\$
Data Classification (\$D\$)	\$30\%\$	RESTRICTED	\$100.0\$
		CONFIDENTIAL	\$75.0\$
		INTERNAL	\$40.0\$
		PUBLIC	\$10.0\$
Network Connectivity (\$N\$)	\$20\%\$	DIRECT_API_VPN_DB	\$100.0\$
		CREDENTIALLED_PORTAL	\$60.0\$
		ISOLATED_SAAS	\$30.0\$
		AIR_GAPPED_OFFLINE	\$0.0\$
PII / Financial Access (\$P\$)	\$10\%\$	DIRECT_PCI_PII_PHI	\$100.0\$
		AGGREGATED_ANONYMIZED	\$50.0\$
		NO_PII_ACCESS	\$0.0\$
Hosting Model (\$H\$)	\$10\%\$	VENDOR_PUBLIC_CLOUD	\$100.0\$
		MULTI_TENANT_SAAS	\$80.0\$
		DEDICATED_HOSTED	\$40.0\$
		ON_PREM_CUSTOMER_DATACENTER	\$10.0\$

7.2 Vendor Inherent Risk & Tier Mapping Engine

VENDOR INHERENT RISK & DETERMINISTIC TIER FORMULA

$$\text{InherentRisk}(V) = \begin{cases} \max_{e \in \text{ActiveEngagements}(V)} \text{EngagementRisk}(e) & \text{if active engagements exist} \\ 0.0 & \text{otherwise} \end{cases}$$

$$\text{CalculatedTier}(V) = \begin{cases} \text{TIER_1_CRITICAL} & \text{if } \text{InherentRisk} \geq 80.0 \text{ or } \exists e \in \text{ActiveEngagements}: C(e) = \text{CRITICAL} \\ \text{TIER_2_SIGNIFICANT} & \text{if } 60.0 \leq \text{InherentRisk} < 80.0 \\ \text{TIER_3_MODERATE} & \text{if } 40.0 \leq \text{InherentRisk} < 60.0 \\ \text{TIER_4_LOW} & \text{if } \text{InherentRisk} < 40.0 \end{cases}$$

Critical Escalation Rule: Any active engagement with Business Criticality = CRITICAL automatically escalates the entire vendor to **TIER_1_CRITICAL** regardless of mathematical score.

7.3 Assessment Scoring Engine

VENDOR ASSESSMENT QUESTIONNAIRE SCORING FORMULA

$$\text{AssessmentScore} = \begin{cases} 100.0 & \text{if all items are NOT_APPLICABLE or } \sum w_i = 0 \\ \frac{\sum_{i \in \text{ApplicableItems}} w_i \cdot R(i)}{\sum_{i \in \text{ApplicableItems}} w_i} \cdot 100.0 & \text{otherwise} \end{cases}$$

Response Values: COMPLIANT \$= 1.0\$ • PARTIALLY_COMPLIANT \$= 0.50\$ • NON_COMPLIANT \$= 0.0\$. Items with response NOT_APPLICABLE are excluded from both numerator and denominator.

7.4 Defensible Residual Risk Engine

VENDOR RESIDUAL RISK FORMULA

$$\text{RiskFloor} = 0.20 \times \text{InherentRisk}$$

$$\text{BaseResidual} = \text{InherentRisk} \times \left(1.0 - 0.70 \times \frac{\text{AssessmentScore}}{100.0} \right) \quad \left(\text{or } \text{InherentRisk} \text{ if unassessed} \right)$$

$$\text{AttenuatedRisk} = \max(\text{RiskFloor}, \text{BaseResidual})$$

$$\text{ResidualRisk} = \text{round}(\max(0.0, \min(100.0, \text{AttenuatedRisk} + P_{\text{finding}} + P_{\text{exception}})), 1)$$

Penalties: Non-compliant finding penalty \$= \min(N_{\text{findings}} \times 8.0, 30.0)\$ • Active third-party security exception \$= N_{\text{exceptions}} \times 10.0\$.

Section 8: Consolidated Threshold & Boundary Reference Matrix

Domain / Category	Metric / Threshold Name	Canonical Boundary / Value	Operational Effect
CCM Health Bands	Healthy Band	$[\$80.0, 100.0]$	Optimal compliance; zero alerts
	Degraded Band	$[\$60.0, 79.9]$	Warning status; review required
	At Risk Band	$[\$40.0, 59.9]$	Triggers High severity drift alert
	Failing Band	$[\$0.0, 39.9]$	Triggers Critical severity drift alert
Vendor Tiers	Tier 1 (Critical)	$\$ \text{ext}\{\text{Risk}\} \geq 80.0 \text{ \textit{or} } C = \text{ext}\{\text{CRIT}\}$	Annual audit; continuous telemetry
	Tier 2 (Significant)	$\$60.0 \leq \text{ext}\{\text{Risk}\} < 80.0$	Annual questionnaire; SOC 2 review
	Tier 3 (Moderate)	$\$40.0 \leq \text{ext}\{\text{Risk}\} < 60.0$	Biennial questionnaire assessment
	Tier 4 (Low)	$\$ \text{ext}\{\text{Risk}\} < 40.0$	Basic contractual due diligence
Vendor Risk Bands	Low Risk Band	$[\$0.0, 39.9]$	Standard operating risk
	Moderate Risk Band	$[\$40.0, 59.9]$	Elevated third-party exposure
	High Risk Band	$[\$60.0, 79.9]$	Significant deficiency; mitigation required
	Critical Risk Band	$[\$80.0, 100.0]$	Unacceptable risk; escalation triggered
Audit Readiness Bands	Ready	$[\$85.0, 100.0]$	Eligible for clean auditor opinion
	Substantially Ready	$[\$60.0, 84.9]$	Minor remediation required
	Partially Ready	$[\$35.0, 59.9]$	Substantial testing gaps
	Not Ready	$[\$0.0, 34.9]$	Assurance engagement blocked
Harmonization Thresholds	Crosswalk Confidence	≥ 0.80 (80.0%)	Minimum score for inherited coverage
	Coverage Health Qualification	$\$ \text{ext}\{\text{CCM}\} \geq 60.0$	Minimum score to count as covered
Timing & Aging Windows	Evidence Max Age ($\$ \text{au}_{\{\text{ext}\{\text{ev}\}}\}$)	$\$90 \text{ ext}\{\text{ days}\}$	Freshness decay begins after 90 days
	Assessment Max Age ($\$ \text{au}_{\{\text{ext}\{\text{assess}\}}\}$)	$\$180 \text{ ext}\{\text{ days}\}$	Overdue assessment penalty after 180 days
Finding SLA Windows	Critical Finding SLA ($\$ \text{au}_{\{\text{ext}\{\text{sla_crit}\}}\}$)	$\$15 \text{ ext}\{\text{ days}\}$	$\$+10 \text{ ext}\{\text{ pt}\}$ penalty after 15 days
	High Finding SLA ($\$ \text{au}_{\{\text{ext}\{\text{sla_high}\}}\}$)	$\$30 \text{ ext}\{\text{ days}\}$	$\$+5 \text{ ext}\{\text{ pt}\}$ penalty after 30 days
Risk Floors & Caps	Residual Risk Floor	$\$20\% \text{ imes ext}\{\text{InherentRisk}\}$	Unmitigatable baseline risk floor
	CCM Penalty Cap	$\$40.0 \text{ ext}\{\text{ points}\}$	Maximum penalty credit deduction

Section 9: Fully Worked Numerical Examples

Example 1: Perfect CCM Control Baseline (Score: 100.0 / HEALTHY)

Inputs: Fresh evidence ($\Delta_{\text{ev}} \leq 90 \text{ d} \implies E = 100.0$), Implemented status assessed 40 d ago ($\Delta_{\text{ev}} \leq 180 \text{ d} \implies A = 100.0$), 0 findings ($P_F = 0$), 0 exceptions ($P_E = 0$).

Calculation:

$$\text{RawScore} = (100.0 \times 0.35) + (100.0 \times 0.25) + (40.0 - \min(40.0, 0.0)) = 35.0 + 25.0 + 40.0 = 100.0$$

Result: $\mathbf{100.0}$ • **HEALTHY**

Example 2: CCM Control with Stale Evidence (135 Days Old)

Inputs: Evidence age $\Delta_{\text{ev}} = 135 \text{ d}$ ($\Delta_{\text{ev}} = 135 - 90 = 45 \text{ d}$), Currency $A = 100.0$, Penalties $P_F = 0$, $P_E = 0$.

Calculation:

$$E = \text{round}\left(\left(1.0 - \frac{45}{90}\right) \times 100.0, 1\right) = 50.0$$

$$\text{RawScore} = (50.0 \times 0.35) + (100.0 \times 0.25) + (40.0 - 0.0) = 17.5 + 25.0 + 40.0 = 82.5$$

Result: $\mathbf{82.5}$ • **HEALTHY**

Example 3: CCM Control with SLA-Breached Critical Finding

Inputs: Fresh evidence $E = 100.0$, Current assessment $A = 100.0$, One Critical finding aged 20 d ($\Delta_{\text{ev}} > 15 \text{ d} \implies P_F = 20.0 + 10.0 = 30.0$).

Calculation:

$$\text{RawScore} = (100.0 \times 0.35) + (100.0 \times 0.25) + (40.0 - \min(40.0, 30.0)) = 35.0 + 25.0 + 10.0 = 70.0$$

Result: $\mathbf{70.0}$ • **DEGRADED**

Example 4: CCM Control with Expired Active Exception and Critical Finding

Inputs: Evidence $E = 100.0$, Currency $A = 100.0$, Critical finding $P_F = 30.0$, Expired Exception $P_E = 15.0$ (Total penalty $= 45.0$).

Calculation:

$$\text{PenaltyDeduction} = \min(40.0, 30.0 + 15.0) = \min(40.0, 45.0) = 40.0$$

$$\text{RawScore} = 35.0 + 25.0 + (40.0 - 40.0) = 60.0$$

Result: $\mathbf{60.0}$ • **DEGRADED** (Boundary Value)

Example 5: Weighted Common Control Inherited Health

Inputs: Common Control mapped to Control 1 (CCM: \$90.0\$, Weight: \$2.0\$) and Control 2 (CCM: \$60.0\$, Weight: \$1.0\$).

Calculation:

$$\text{WeightedSum} = (2.0 \times 90.0) + (1.0 \times 60.0) = 180.0 + 60.0 = 240.0, \quad \text{TotalWeight} = 3.0$$

$$\text{InheritedHealth} = \text{round}\left(\frac{240.0}{3.0}, 1\right) = 80.0$$

Result: $\mathbf{80.0}$ • **HEALTHY**

Example 6: Inherited Framework Coverage & Multi-Candidate Selection

Inputs: Target subcategory s has no direct control. Two crosswalks: CW1 (\$\text{source CCM} = 90.0\$, \$\text{confidence} = 0.90\$), CW2 (\$\text{source CCM} = 100.0\$, \$\text{confidence} = 0.80\$).

Candidate Evaluation:

- CW1: \$\text{EffectiveHealth} = \text{round}(90.0 \times 0.90, 1) = 81.0\$
- CW2: \$\text{EffectiveHealth} = \text{round}(100.0 \times 0.80, 1) = 80.0\$

Selection: CW1 selected (\$81.0 > 80.0\$). Subcategory s is covered with \$\text{EffectiveHealth} = \mathbf{81.0}\$.

Example 7: Vendor Engagement Risk & Tier Escalation

Inputs: Engagement: Criticality = HIGH (\$75\$), Data = RESTRICTED (\$100\$), Network = DIRECT_API_VPN_DB (\$100\$), PII = DIRECT_PCI_PII_PHI (\$100\$), Hosting = MULTI_TENANT_SAAS (\$80\$).

Calculation:

$$\text{Risk} = (0.30 \times 75) + (0.30 \times 100) + (0.20 \times 100) + (0.10 \times 100) + (0.10 \times 80) = 22.5 + 30.0 + 20.0 + 10.0 + 8.0 = 90.5$$

Result: Inherent Risk = $\mathbf{90.5}$ • **TIER_1_CRITICAL** (\$90.5 \geq 80.0\$)

Example 8: Vendor Assessment Questionnaire Scoring

Inputs: Item 1 (Weight: 2.0, COMPLIANT \$= 1.0\$), Item 2 (Weight: 1.0, PARTIALLY_COMPLIANT \$= 0.50\$), Item 3 (Weight: 3.0, NOT_APPLICABLE).

Calculation: Item 3 is excluded. Applicable Weight \$= 2.0 + 1.0 = 3.0\$.

$$\text{AssessmentScore} = \text{round}\left(\frac{2.0 \times 1.0 + 1.0 \times 0.50}{3.0} \times 100.0, 1\right) = \text{round}\left(\frac{2.5}{3.0} \times 100.0, 1\right) = 83.3\%$$

Result: $\mathbf{83.3\%}$

Example 9: Vendor Residual Risk with Attenuation, Floor & Penalties

Inputs: $\text{InherentRisk} = 90.5$, $\text{AssessmentScore} = 83.3\%$, 1 finding ($P_{\text{find}} = 8.0\%$), 0 exceptions ($P_{\text{exc}} = 0\%$).

Step-by-Step Calculation:

$$\text{RiskFloor} = 0.20 \times 90.5 = 18.1$$

$$\text{BaseResidual} = 90.5 \times \left(1.0 - 0.70 \times \frac{83.3}{100.0}\right) = 90.5 \times (1.0 - 0.5831) = 90.5 \times 0.4169 = 37.73$$

$$\text{AttenuatedRisk} = \max(18.1, 37.73) = 37.73$$

$$\text{ResidualRisk} = \text{round}(37.73 + 8.0, 1) = 45.7$$

Result: Residual Risk = $\mathbf{45.7}$ • **MODERATE** ($40.0 \leq 45.7 < 60.0$)

Section 10: Formula Dependency Lineage & Telemetry Propagation

ControlSphere's deterministic calculations flow through a unidirectional, strictly typed telemetry pipeline where lower-level operational states feed higher-level executive indexes:

TELEMETRY PROPAGATION GRAPH

[Phase 3: Evidence Items] — (Age, Status: ACCEPTED) | ▼ [Phase 2: Org Controls] —> [Phase 7: Continuous Control Monitoring] ← [Phase 4: Findings] (Status: IMPLEMENTED) (Evidence Freshness: $E * 0.35$) (Open Severities, SLA) (Assessment Currency: $A * 0.25$) (Penalty Credit: $40 - \min(40, PF + PE)$) ← [Phase 5: Exceptions] | (Approved, Expired) ▼ [Phase 8: Harmonization Engine] |→ Rationalized Common Control Health (Weighted Sum) |→ Multi-Framework Compliance Posture & Coverage % | ▼ [Phase 9: TPRM Governance] |→ Inherent Risk & Tier (Max Engagement Risk) |→ Residual Risk = $\text{clamp}(\max(\text{Floor}, \text{Base}) + P_{\text{finding}} + P_{\text{exception}})$

Telemetry Separation vs. Reuse Rules

- Reused Telemetry:** Phase 8 Harmonization directly consumes Phase 7 CCM snapshots. Phase 9 TPRM links to Phase 3 Evidence items and Phase 4 Findings without duplicating file storage or finding models.
- Independent Scoring Modules:** Phase 6 Audit Readiness operates on its own dedicated assurance formula ($\$0.40 \text{ ext}\{\text{Proc}\} + 0.30 \text{ ext}\{\text{Evd}\} - P_{\text{ext}\{\text{audit}\}})$ tailored for external auditors, while Phase 7 CCM computes continuous internal operational health.

Section 11: Specification vs. Implementation Notes

Feature Area	Canonical Specification	Production Implementation	Audit Assessment & Status
CCM Master Formula	$E \text{ imes } 0.35 + A \text{ imes } 0.25 + (40 - \min(40, P_F + P_E))\$$	MonitoringService._evaluate_single_control	100% Exact Match: Formulas, decay slopes, and penalty caps are identical.
Common Control Zero Mapping	Evaluates to 100.0 / HEALTHY	HarmonizationService.recalculate_common_control_health	100% Exact Match: Unmapped common controls default safely to 100.0.
Assessment Transition Pipeline	$\$ \text{ ext}\{\text{DRAFT}\} \text{ ightarrow ext}\{\text{SUBMITTED}\} \text{ ightarrow ext}\{\text{IN_REVIEW}\}\$$	endpoints/tprm.py + start-review	Audited & Hardened: Explicit two-step submission and review verified.
Residual Risk Floor	$\$ \text{ ext}\{\text{Floor}\} = 0.20 \text{ imes ext}\{\text{InherentRisk}\}\$$	TPRMService.calculate_vendor_residual_risk	100% Exact Match: Implements defensible $\$20\%\$$ non-zero risk floor.
Finding SLA Penalties	Critical: 15d (+10), High: 30d (+5)	MonitoringService config defaults	100% Exact Match: SLA breach surcharges correctly applied in CCM.

Section 12: Source Code & Test Reference Directory

Engine / Formula	Primary Service File	Primary ORM Model	Primary Pytest Test File
Control Compliance Score	app/services/control_service.py	OrganizationControl	tests/test_controls.py
Evidence Coverage %	app/services/evidence_service.py	EvidenceItem, EvidenceRequirement	tests/test_evidence_assurance_metrics.py
Risk Matrix & Appetite	app/core/risk_engine.py	Finding, Risk	tests/test_risks.py, tests/test_findings.py
Audit Readiness Engine	app/services/audit_engagement_service.py	Audit, AuditProcedure	tests/test_audit_procedures.py
CCM Continuous Health	app/services/monitoring_service.py	ControlHealthSnapshot	tests/test_monitoring_engine.py, tests/test_monitoring_mathematical_precision.py
Harmonization & Crosswalks	app/services/harmonization_service.py	RationalizedCommonControl, FrameworkCrosswalkMapping	tests/test_harmonization_engine.py
TPRM Risk & Tier Engine	app/services/tprm_service.py	Vendor, VendorEngagement, VendorAssessment	tests/test_tprm_engine.py, tests/test_tprm_domain.py

Section 13: Formula Quick Reference (Engineering Cheat Sheet)

1. MASTER CCM HEALTH SCORE (PHASE 7)

$$\text{HealthScore} = \text{round}\left(\frac{\text{clamp}\left(\text{Big}\left((E \times 0.35) + (A \times 0.25) + (40.0 - \min(40.0, P_F + P_E)), \backslash, 0.0, \backslash, 100.0\right)\right)}{1}, 1\right)$$

2. HARMONIZED FRAMEWORK COMPLIANCE HEALTH (PHASE 8)

$$\begin{aligned} \text{ComplianceScore}(F) &= \text{round}\left(\frac{\sum_{s \in S_{\text{covered}}}\text{EffectiveHealth}(s)}{N_F}, 1\right), \\ \text{CoveragePct}(F) &= \text{round}\left(\frac{\sum_{s \in S_{\text{covered}}}\text{EffectiveHealth}(s)}{N_F} \times 100.0, 1\right) \end{aligned}$$

3. VENDOR INHERENT RISK & TIERING (PHASE 9)

$$\text{EngagementRisk} = \text{round}(0.30C + 0.30D + 0.20N + 0.10P + 0.10H, 1), \quad \text{InherentRisk} = \max_{e \in \text{Active}}(\text{EngagementRisk}(e))$$

$$\text{Tier 1} \geq 80.0 \vee C = \text{CRITICAL} \quad \text{Tier 2: } [60, 79.9] \quad \text{Tier 3: } [40, 59.9] \quad \text{Tier 4} < 40$$

4. VENDOR RESIDUAL RISK (PHASE 9)

$$\text{ResidualRisk} = \text{clamp}\left(\frac{\max(0.20 \cdot I, I \cdot (1.0 - 0.70 \cdot \text{Score})/100.0)}{1} + P_{\text{find}} + P_{\text{exc}}, \backslash, 0.0, \backslash, 100.0\right)$$

5. AUDIT READINESS MASTER SCORE (PHASE 6)

$$\text{ReadinessScore} = \text{round}\left(\frac{\text{clamp}\left(\text{Big}\left((\text{Score}_{\text{proc}} \times 0.40) + (\text{Score}_{\text{evd}} \times 0.30) - P_{\text{audit}}, \backslash, 0.0, \backslash, 100.0\right)\right)}{1}, 1\right)$$

6. RISK MATRIX & RISK REDUCTION % (PHASES 4 & 5)

$$\text{RiskScore} = \text{Impact} \times \text{Likelihood} \in [1, 25], \quad \text{ReductionPct} = \text{round}\left(\frac{I_{\text{total}} - R_{\text{total}}}{I_{\text{total}}} \times 100.0, 1\right)$$